Análise do projeto oauth-pages-lab

Repositório: github.com/Beatrys-lira/oauth-pages-lab | Site: oauth-pages-lab-ec6.pages.dev | Data: 14/10/2026

1. Escopo da análise

O que foi lido: README.md, AVALIACAO.md, wrangler.toml e o HTML inicial do site publicado.

O que não foi lido: o código das pastas `functions/`, `.github/workflows/`, `migrations/` e `public/`, porque o GitHub bloqueou o acesso automático a essas páginas. Por isso, o que o README afirma sobre segurança (sessão no servidor, cookie protegido) aparece aqui como *declarado*, não como *confirmado no código*. A seção 4 lista o que vale conferir.

2. Resumo do projeto

Site de login com conta Google (OpenID Connect) ou GitHub (OAuth). Após entrar, a pessoa vê um painel com gráficos de ocupações de Engenharia de Software, com nome e foto do provedor. A hospedagem é no Cloudflare Pages, com Pages Functions para a autenticação, banco Cloudflare D1 para usuários e sessões, e GitHub Actions para testes, revisão por IA e migrações.

3. Pontos fortes

- **README completo:** fluxo de login em cinco passos, tecnologias, organização das pastas, configuração necessária e as URLs de retorno dos dois provedores.
- **Sessão no servidor:** segundo o README, a sessão fica no D1 e o cookie não pode ser lido pelo JavaScript da página, que é a prática recomendada.
- **Segredos fora do repositório:** IDs e segredos dos clientes ficam nas configurações do Cloudflare. O wrangler.toml traz apenas valores não secretos.
- **Evidências sólidas no AVALIACAO.md:** links de execuções verde e vermelha, falhas provocadas de propósito (`CREATE TABL`), push direto recusado na main (GH006), teste sem a permissão `pull-requests: write` e confirmação da migração no D1 remoto com `PRAGMA table_info`.
- **Senso crítico sobre a IA:** o documento aponta e justifica o erro da revisão automática (sobre o campo *model* vazio) em vez de aceitá-la.
- **Permissões mínimas:** o CI final voltou a usar só `contents: read`, e o job temporário com escrita foi removido após o teste.
- **Fluxo profissional:** alterações entram por pull request com check obrigatório na main protegida; o histórico tem 92 commits.
- **Honestidade nos dados:** o README deixa claro que os gráficos usam projeções do BLS para os EUA (2025 a 2035), não vagas atuais nem dados do Brasil.

4. Pontos de atenção e sugestões

#	Observação	Por que importa / sugestão	Prioridade
1	**Arquivos em** `public/entrega1`	Tudo que está em `public/` é servido no site. Confira se os prints e arquivos dessa pasta não mostram e-mail, tokens, IDs de cliente ou outros dados pessoais. Se mostrarem, esconda esses trechos ou mova as evidências para fora de `public/`.	Alta
2	**Pull request aberto**	A página do repositório lista 1 pull request aberto. Veja se é intencional. Se não for, integre ou feche antes da entrega, para não parecer trabalho pendente.	Média

#	Observação	Por que importa / sugestão	Prioridade
3	**Banco de usuários e sessões**	O README diz que o D1 guarda usuários e sessões, mas o AVALIACAO.md só cita as migrações da tabela *notas* (0001 e 0002). Confirme que `migrations/` também cria as tabelas de usuários e sessões, para o projeto ser reproduzível do zero.	Média
4	**Tela inicial "Consultando sua sessão..."**	O HTML inicial só mostra esse texto enquanto o JavaScript consulta a API. Sem JavaScript, ou se a API demorar ou falhar, a pessoa fica sem saber o que fazer. Sugestão: mostrar os botões de login por padrão, ou exibir uma mensagem de erro após um tempo limite.	Média
5	**Prints complementares**	O AVALIACAO.md diz que os prints do PR bloqueado e do PR liberado foram capturados, mas não diz onde estão. Acrescente o caminho do arquivo ou um link.	Baixa
6	**Resposta 1 (CI roda duas vezes)**	Explica o motivo (eventos *push* e *pull_request*), mas não diz como evitar. Se fizer sentido no seu ci.yml, acrescente uma frase sobre limitar o *push* à main ou usar *concurrency*. Confira o arquivo antes de afirmar.	Baixa
7	**Resposta 2 (fork e segredos)**	Está correta. Pode ganhar uma linha extra: em pull requests de fork, o GITHUB_TOKEN também vem com acesso somente de leitura.	Baixa
8	**Ressalva dos dados no painel**	O README explica que os dados são dos EUA. Confirme que o painel também mostra essa ressalva (por exemplo, numa nota abaixo dos gráficos).	Baixa
9	`database_id` **no wrangler.toml**	O ID do banco aparece no arquivo público. Isso não é um segredo e não dá acesso sem o token da Cloudflare, então pode ficar. Apenas confirme que nenhum token ou ID de conta foi parar no repositório.	Informativa

5. Para conferir no código (não verificado)

Estes itens dependem de ler a pasta `functions/`. São os pontos mais comuns de falha em login OAuth:

- O parâmetro *state* é gerado, guardado e comparado na volta do provedor (protege contra CSRF no login).
- No Google, o *nonce* e o ID token são validados; PKCE, se usado, está completo.
- O cookie de sessão tem *HttpOnly*, *Secure* e *SameSite*, e a sessão tem prazo de expiração.
- O endereço de retorno vem de `PUBLIC_BASE_URL` e não de dados enviados pelo navegador.
- O logout apaga a sessão no D1, e não só o cookie.
- O GitHub pode não devolver e-mail; o painel precisa tratar esse caso sem erro.
- Todas as consultas ao D1 usam `prepare().bind()`, como já foi corrigido no PR #1.

6. Conclusão

Pelo que foi possível verificar, o projeto está bem documentado e as evidências da avaliação são fortes, com falhas testadas de propósito e crítica honesta à revisão por IA. Antes da entrega, o mais urgente é conferir o conteúdo de `public/entrega1` e decidir sobre o pull request aberto. Se quiser uma análise do código de autenticação e dos workflows, cole os arquivos de `functions/` e `.github/workflows/` e a revisão pode ser completada.